

PROJECT CERBERUS

Construire une défense multi-couches, du code jusqu'à l'exécution en production.

Niveau visé : Confirmé (1-3 ans) | Durée estimée : 5 à 6 semaines, à temps partiel | Format : projet solo, autonomie totale

Contexte

NEXUS CORP, une entreprise fictive, fait tourner ses services sur Kubernetes avec une infrastructure provisionnée via Terraform. Rien n'a jamais été testé en conditions réelles : pas de test dynamique, pas d'audit de l'infrastructure, aucune traçabilité des composants logiciels utilisés. Un audit externe vient d'alerter la direction. Tu es mandaté(e) pour construire une défense qui couvre l'ensemble de la chaîne : le code, l'infrastructure, le cluster, et les artefacts livrés.

Objectifs pédagogiques

- Maîtriser le test dynamique d'application (**DAST**) sur une application en exécution.
- Sécuriser une infrastructure définie en code (**laC**) avant qu'elle ne soit déployée.
- Durcir un cluster Kubernetes : accès, réseau, exécution des workloads.
- Générer et signer une nomenclature logicielle (**SBOM**) pour tracer chaque composant livré.
- Réaliser un premier exercice de threat modeling pour identifier les surfaces d'attaque du système.

Compétences visées

Compétence	Ce que tu dois savoir faire / outils
DAST	OWASP ZAP ou Burp — tester une application déployée en staging pour détecter les failles runtime (auth, headers, entrées mal validées).
laC scanning	Checkov ou Terrascan — scanner un projet Terraform avant tout déploiement.
Kubernetes hardening	Politiques d'admission, RBAC, network policies — empêcher l'exécution de workloads non conformes.
SBOM & signature	Syft pour générer la nomenclature logicielle, Sigstore pour signer les artefacts produits.
Threat modeling (niveau 1)	Identifier et prioriser les principales surfaces d'attaque du système étudié.

Livrables attendus

- Infrastructure Terraform provisionnant un cluster (ou simulation locale type kind / k3d).

- Rapport DAST complet sur une application déployée en environnement de staging.
- Politiques d'admission Kubernetes actives, testées et documentées.
- SBOM généré et signé automatiquement pour chaque build.
- Document de threat modeling : schéma d'architecture + liste de risques priorisés.

Contraintes techniques obligatoires

- Le cluster ne doit accepter **aucun pod tournant en root** (démonstré par une admission policy active).
- Toute CVE critique détectée par le scan IaC doit bloquer automatiquement le déploiement.
- Le SBOM doit être généré à chaque build automatiquement — pas manuellement, pas ponctuellement.

Critères d'évaluation

Critère d'évaluation	Poids
Robustesse de l'infrastructure et des politiques Kubernetes	35%
Qualité de l'analyse DAST et pertinence des corrections	25%
SBOM et signature fonctionnels et automatisés	20%
Qualité et clarté du threat modeling	20%

Ce sujet est conçu pour être réalisé en autonomie complète. Aucune correction type n'existe : documente tes choix, assume-les, et sois capable de les défendre à l'oral face à un recruteur comme tu le ferais face à un jury.